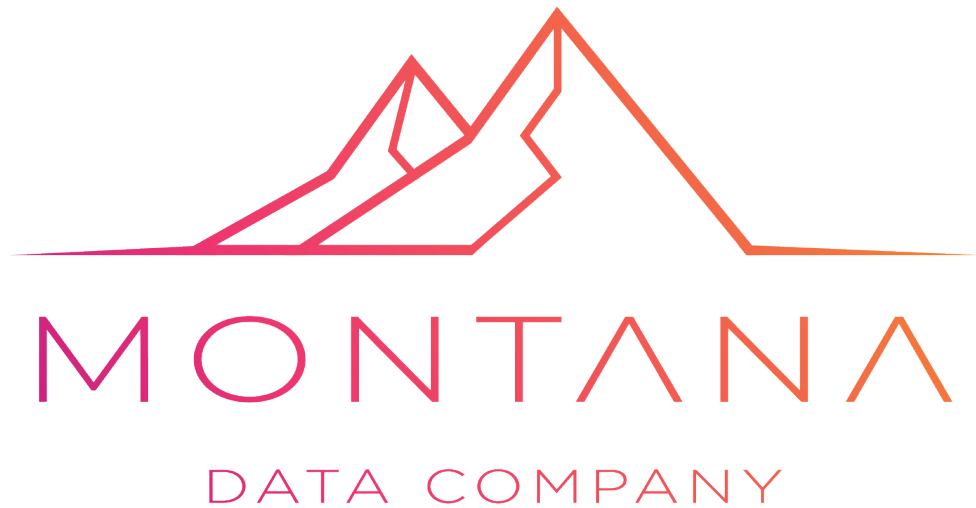




POPIA COMPLIANCE CHECKLIST FOR SMES

Montana Data Company (Pty) Ltd
Suite 24, Frazzitta Business Park
Corner Langeberg & Batis Roads
Durbanville
Western Cape
7550
South Africa

Disclaimer

The information contained in this document is provided by Montana Data Company (Montana) for general informational and educational purposes only. While every effort has been made to ensure that the content is accurate, current, and relevant at the time of publication, no representation or warranty, express or implied, is made regarding the completeness, accuracy, reliability, suitability, or availability of the information contained herein.

Each organisation is unique and therefore faces unique operational, legal, regulatory, cybersecurity, and business continuity challenges that must be assessed and addressed according to its specific circumstances, risk profile, industry obligations, and operational environment. The guidance, frameworks, checklists, templates, and recommendations contained in this document are intended as general guidance only and may not be suitable for every organisation or situation.

This document does not constitute legal, regulatory, financial, cybersecurity, forensic, insurance, compliance, or other professional advice. Readers should not rely solely on the information contained in this document when making business, legal, technical, operational, or incident response decisions. Independent professional advice appropriate to the organisation's specific circumstances should be obtained where necessary.

Where this document relates to cybersecurity incidents, ransomware response, disaster recovery, compliance, governance, or operational resilience, the content is intended to provide general operational guidance only. It should not be interpreted as legal advice, digital forensic advice, cyber insurance guidance, regulatory guidance, or a substitute for qualified professional consultation during an active incident or compliance matter.

Any references to legislation, standards, frameworks, regulatory requirements, or best practices — including but not limited to privacy laws, data protection obligations, cybersecurity frameworks, business continuity standards, or compliance requirements — may change over time and may vary by jurisdiction. It remains the responsibility of the reader to ensure compliance with all applicable laws, regulations, contractual obligations, and industry-specific requirements.

Montana shall not be liable for any direct, indirect, incidental, consequential, or special loss or damage arising from the use of, or reliance on, the information contained in this document.

All content contained in this document remains the intellectual property of Montana unless otherwise stated. This material may not be reproduced, distributed, modified, republished, or transmitted in any form or by any means without prior written permission, except for reasonable internal business use by the original recipient.

Any third-party products, services, trademarks, standards, vendor names, or technologies referenced in this document remain the property of their respective owners and are referenced for informational purposes only. Such references do not imply endorsement, partnership, or affiliation unless explicitly stated.

By accessing, downloading, or using this document, the reader acknowledges and agrees to the terms of this disclaimer.

Last Updated: April 2026

Introduction

POPIA compliance is not a once-off exercise. It requires ongoing governance, operational oversight, staff awareness, and appropriate security controls to protect personal information throughout its lifecycle.

This checklist is designed to help SMEs identify foundational operational controls that support responsible handling of personal information across business processes, systems, employees, and third-party service providers.

1. Governance & Accountability

- ☐ Information Officer formally designated
- ☐ Information Officer responsibilities documented
- ☐ POPIA responsibilities assigned internally
- ☐ Management aware of POPIA accountability obligations
- ☐ Privacy and information handling responsibilities communicated to staff
- ☐ POPIA-related policies approved and maintained
- ☐ Personal information processing activities periodically reviewed
- ☐ Third-party operators identified and documented

2. Personal Information Management

- ☐ Customer personal information identified
- ☐ Employee personal information identified
- ☐ Supplier and vendor information identified
- ☐ Storage locations for personal information documented
- ☐ Shared drives reviewed for sensitive information exposure
- ☐ Personal information stored on portable devices identified
- ☐ Unnecessary or duplicate personal information removed
- ☐ Retention periods defined for records containing personal information
- ☐ Physical records secured appropriately
- ☐ Archived records reviewed periodically

3. Collection & Processing Controls

- ☐ Personal information collected for defined business purposes
- ☐ Information collection limited to necessary data only
- ☐ Privacy notices available where required
- ☐ Consent mechanisms documented where applicable
- ☐ Special personal information identified and appropriately protected
- ☐ Customer-facing forms reviewed for excessive data collection
- ☐ Marketing communications reviewed for POPIA alignment
- ☐ Personal information accuracy reviewed periodically
- ☐ Retention and disposal practices defined

4. Access Control & Security Safeguards

- ☐ Strong password practices enforced
- ☐ Multi-factor authentication enabled where possible

- ☐ User access restricted based on business need
- ☐ User access reviewed regularly
- ☐ Former employee access revoked immediately upon termination
- ☐ Sensitive files access-restricted
- ☐ Antivirus or endpoint protection implemented
- ☐ Systems regularly updated and patched
- ☐ Backups performed regularly
- ☐ Backup restoration procedures tested
- ☐ Portable devices encrypted where possible
- ☐ Wi-Fi networks secured appropriately
- ☐ Remote access secured
- ☐ Paper records stored securely
- ☐ Confidential records disposed of securely
- ☐ Shared accounts minimised or eliminated

5. Third-Party Operators & Service Providers

- ☐ Operators handling personal information identified
- ☐ Third-party service providers reviewed for security practices
- ☐ Confidentiality obligations documented
- ☐ Breach notification responsibilities defined
- ☐ Cloud platforms reviewed for appropriate security safeguards
- ☐ Third-party access to systems reviewed periodically
- ☐ Operator agreements reviewed for privacy obligations

6. Data Subject Request Handling

- ☐ Process exists for access requests
- ☐ Correction requests can be managed appropriately
- ☐ Deletion requests can be escalated where applicable
- ☐ Objection to processing requests can be reviewed
- ☐ Complaints handling process defined
- ☐ Requests and responses documented appropriately

7. Security Incident & Breach Response

- ☐ Staff know how to report security incidents
- ☐ Security incidents documented and tracked
- ☐ Personal information breaches logged
- ☐ Incident response responsibilities assigned
- ☐ Escalation procedures defined
- ☐ Backup recovery procedures tested
- ☐ Contact process exists for affected parties if required
- ☐ External service providers understand escalation requirements

8. Staff Awareness & Training

- ☐ Staff trained on handling personal information responsibly

- ☐ New employees receive privacy awareness onboarding
- ☐ Staff understand phishing and social engineering risks
- ☐ Remote work security expectations communicated
- ☐ Staff aware of incident reporting procedures
- ☐ Confidential information handling expectations communicated clearly

9. Operational Review Checklist

- ☐ POPIA controls reviewed periodically
- ☐ Policies reviewed and updated where required
- ☐ Security controls assessed regularly
- ☐ Third-party providers reviewed periodically
- ☐ Access rights reviewed regularly
- ☐ High-risk information repositories monitored
- ☐ Incident trends reviewed for recurring risks

10. Common SME POPIA Risk Areas

- ☐ Shared user accounts
- ☐ Excessive collection of personal information
- ☐ Lack of access control reviews
- ☐ Unsecured spreadsheets containing customer data
- ☐ No documented retention practices
- ☐ Inadequate operator oversight
- ☐ Informal sharing of information through messaging platforms
- ☐ Lack of employee awareness training
- ☐ Unencrypted laptops or portable devices
- ☐ Failure to revoke access for former employees

Need Assistance with POPIA Governance?

Montana Data Company assists SMEs with practical, risk-based POPIA governance implementation, including readiness reviews, governance framework development, policy development, operator reviews, incident response planning, and staff awareness training.

Email: info@montanadc.com
Phone: +27 87 188 3843